

Security Risk Assessment Report

8 April 2026

Executive Summary

The assessment identified moderate security risks related to shared network architecture, physical asset exposure, and operational access control procedures.

Limited technical testing identified insufficient network segmentation between guest and administrative devices, while physical assessment identified risks associated with publicly accessible high-value assets.

Most identified risks can be mitigated through relatively low-cost organisational and technical improvements.

System Description

[REDACTED] is a department store located in [REDACTED], Czech Republic. Currently, available services include [REDACTED], [REDACTED], and others. In the future, the building is also planned to include a gallery and potentially serve as a community centre.

Customers can access services such as a shared password-protected WiFi network, bicycle stands, and freely available umbrellas. If no department is open, the entire building remains closed. At the moment, operating hours are individually arranged by appointment.

The main entrance is secured by a shared key, while each department has its own unique key. The second floor is additionally secured by another separate key, which is planned to be discontinued once the gallery is opened.

Scope

The scope of this security assessment relates to the current access controls, network infrastructure, and physical security controls of the building.

The assessment covers a three-month period from February 2026 to April 2026.

National Institute of Standards and Technology SP 800-30 Rev. 1 and National Institute of Standards and Technology SP 800-53 Rev. 5 were used as guidance frameworks for the risk analysis of the information system and the physical infrastructure.

Purpose

Department store [REDACTED] stores valuable physical assets in separate departments and provides customer services that could potentially be abused if not properly secured (e.g. NAS access, WiFi access, bicycles, umbrellas).

Businesses located in the building also store physical documents containing customers' personally identifiable information (PII), increasing the importance of properly securing each department and shared space.

Methodology

The assessment was conducted using qualitative risk analysis principles derived from NIST SP 800-30 Rev. 1 and selected security control recommendations from NIST SP 800-53 Rev. 5.

The assessment included limited wireless security validation through WPA2 handshake capture, password strength testing against common dictionary-based attacks, and the use of publicly available password strength assessment tools.

The process included:

- identification of critical assets,
- identification of potential threat sources,
- analysis of existing physical and technical controls,
- estimation of likelihood and impact,
- recommendation of mitigation measures.

Risk values were calculated using a simplified qualitative scoring model:

Risk = Likelihood × Severity, where:

1 = Low, 2 = Medium, 3 = High

Assets

It is important to distinguish between assets and their relative value within [REDACTED].

High-value assets are assets whose loss would significantly affect the reputation or financial stability of the department store. These may include customers' bicycles, whose value can reach up to approximately EUR 8,000. Such a loss could represent a significant financial impact relative to the organisation's available resources.

Art pieces also represent high-value assets. Although their direct financial value may sometimes be lower, they are often borrowed, and their loss or damage could negatively affect the organisation's reputation and future partnerships.

Low-value assets are assets that can be replaced relatively easily and with limited financial or reputational impact.

Existing Security Controls

The organisation currently implements several basic security measures, including:

- locked main entrances,
- separate keys for departments,
- strong password-protected WPA2-PSK WiFi,
- restricted building access outside appointment hours,
- shared responsibility for physical security.

These measures provide a basic level of protection but lack centralised management and formalised procedures.

Findings

Shared Network Architecture

Administrative and guest devices currently operate within the same network environment, increasing the potential attack surface in the event of unauthorised access to the guest network.

Physical Asset Exposure

High-value assets such as bicycles and artwork may be vulnerable to opportunistic theft due to limited physical monitoring and insufficient theft deterrence measures.

Operational Access Control Risk

Building access procedures currently rely heavily on manual coordination and individual responsibility, increasing the possibility of incorrect locking procedures.

Wireless Network Security

The wireless network currently relies on WPA2-PSK authentication. While the password strength was assessed as strong during testing, shared-password environments inherently increase long-term credential exposure risk.

Risk Assessment

Threat Source	Threat Event	Likelihood	Severity	Risk
Hacker	WPA2-PSK networks inherently remain susceptible to offline brute-force attacks if credentials are exposed or weak passwords are used.	2	3	6
Hacker	Internal servers may be accessible from the shared network	1	3	3
Hacker	Administrative devices are connected to the same network as guest devices	2	3	6
Robber	Theft of physically accessible high-value assets (e.g. bicycles, artwork)	3	3	9
Robber	Theft of physically accessible low-value assets (e.g. umbrellas, tools)	3	1	3

Departments	Incorrect locking or unlocking of entrances and department doors	3	3	9
-------------	--	---	---	---

Remediation Strategy

Network Security

Implementation of a separated guest network using subnetting or VLAN segmentation is highly recommended.

The guest network may support both WPA2 and WPA3 protocols for compatibility reasons; however, the primary administrative network should use WPA3 exclusively whenever possible.

Administrative NAS access should only be available from the internal administrative network or through secured VPN access with properly managed authentication credentials.

Bandwidth limits of approximately 10–20 Mb/s per connected device are recommended to reduce potential WiFi abuse by non-visitors. Automatic session timeouts after approximately two hours may also reduce long-term misuse of the guest network.

Additional protections such as firewall policies, DNS filtering, and basic content filtering are recommended to reduce access to malicious or inappropriate content.

Entrance Security

An internal physical presence board could help track which individuals are currently present in the building. This may reduce the risk of accidentally locking someone inside or unintentionally leaving entrances unlocked under the assumption that another person is still present.

Department owners should also be periodically reminded about proper locking procedures for both the main entrance and individual department doors.

Bicycles and Other High-Value Assets

The bicycle stand should be permanently fixed to the ground to reduce the risk of theft.

If legally and financially possible, IP cameras should monitor bicycle stands and other locations containing high-value assets.

Customers should also be informed through visible warning signs that bicycles must be secured using their own personal locks.

Priority	Recommendation	Reason
High	Separate guest and administrative network	Reduces attack surface
High	Improve door locking procedures	Reduces physical intrusion risk
Medium	Install IP cameras	Improves deterrence
Low	Session timeout for guest WiFi	Reduces misuse

Residual Risk

Even after implementation of recommended mitigations, certain risks remain unavoidable due to the public and shared nature of the building environment.

Residual risks primarily include:

- opportunistic theft,
- human operational error,
- misuse of publicly accessible services.

Assumptions and Limitations

The assessment included password strength validation and limited wireless security testing of the wireless network and internal access controls.

However, the assessment did not include:

- long-term traffic monitoring,
- full-scale vulnerability scanning,
- social engineering testing,
- source code review,
- forensic analysis,
- advanced wireless packet analysis.

The assessment also assumes that all currently described systems and procedures are representative of normal operational conditions.

References

NIST SP 800-30 Rev.1 – Guide for Conducting Risk Assessments

NIST SP 800-53 Rev.5 – Security and Privacy Controls

OWASP Risk Rating Methodology